



RV College of Engineering®

Mysore Road, RV Vidyaniketan Post, Bengaluru - 560059, Karnataka, India

Go, change the world

Non-Human Identity Governance Agent

Major Project Report (IS481P)

Submitted by,

Manu Prakash Bhat

1RV22IS035

Under the guidance of

Dr. Merin Meleet

Associate Professor

Dept. of ISE

RV College of Engineering

Mr. Tejeshwar Rao

Manager DevSecOps & Cloud

DevSecOps & Cloud Engineering

Honeywell Technology Solutions

In partial fulfillment of the requirements for the degree of

Bachelor of Engineering in

Information Science and Engineering

2025-26

RV College of Engineering®, Bengaluru
(*Autonomous institution affiliated to VTU, Belagavi*)
Department of Information Science and Engineering



CERTIFICATE

Certified that the major project (IS481P) work titled ***Non-Human Identity Governance Agent*** is carried out by **Manu Prakash Bhat (1RV22IS035)** who is bonafide student of RV College of Engineering, Bengaluru, in partial fulfillment of the requirements for the degree of **Bachelor of Engineering in Information Science and Engineering** of the Visvesvaraya Technological University, Belagavi during the year 2025-26. It is certified that all corrections/suggestions indicated for the Internal Assessment have been incorporated in the major project report deposited in the departmental library. The major project report has been approved as it satisfies the academic requirements in respect of major project work prescribed by the institution for the said degree.

Guide	Head of the Department	Principal
Dr. Merin Meleet	Dr. G S Mamatha	Dr. K. N. Subramanya

External Viva

Name of Examiners	Signature with Date
1.	
2.	

DECLARATION

I, **Manu Prakash Bhat** student of eighth semester B.E., Department of Information Science and Engineering, RV College of Engineering, Bengaluru, hereby declare that the major project titled '**Non-Human Identity Governance Agent**' has been carried out by me and submitted in partial fulfilment for the award of degree of **Bachelor of Engineering in Information Science and Engineering** during the year 2025-26.

Further I declare that the content of the dissertation has not been submitted previously by anybody for the award of any degree or diploma to any other university.

I also declare that any Intellectual Property Rights generated out of this project carried out at RVCE will be the property of RV College of Engineering, Bengaluru and I will be one of the authors of the same.

Place: Bengaluru

Date:

Name

Signature

1. Manu Prakash Bhat(1RV22IS035)

ACKNOWLEDGEMENTS

I am indebted to my guide, **Dr. Merin Meleet**, Associate Professor, Department of ISE, RVCE for the wholehearted support, suggestions and invaluable advice throughout my project work and also helped in the preparation of this thesis.

My sincere thanks to the project coordinator **Dr. Vanishree K**, Associate Professor, Department of ISE for the timely instructions and support in coordinating the project.

My gratitude to **Prof. Narashimaraja P**, Department of ECE, RVCE for the organized latex template which made report writing easy and interesting.

My sincere thanks to **Dr. G S Mamatha**, Professor and Head, Department of Information Science and Engineering, RVCE for the support and encouragement.

I express sincere gratitude to our beloved Professor and Vice Principal, **Dr. Geetha K S**, RVCE and Principal, **Dr. K. N. Subramanya**, RVCE for the appreciation towards this project work.

I thank all the teaching staff and technical staff of Information Science and Engineering department, RVCE for their help.

Lastly, I take this opportunity to thank my family members and friends who provided all the backup support throughout the project work.

ABSTRACT

The proliferation of cloud-native architectures and DevOps automation has led to a massive growth in Non-Human Identity (NHI) such as service principals, API keys, GitHub tokens, and managed identities, which now outnumber human users by ratios of up to 144:1 in enterprise environments. Despite this, NHIs receive disproportionately less governance attention, creating a significant security blind spot that credential-based attacks consistently exploit. Industry data from the OWASP NHI Top 10 (2025) reports that 70% of organisations have plaintext secrets in source repositories.

This project delivers an AI-powered NHI Governance Agent that continuously discovers, classifies, governs, and rotates non-human identities across Azure and GitHub ecosystems. The system is designed as a four-layer modular architecture: continuous discovery via Microsoft Graph API and OpenSSL TLS probes, AI-driven risk classification using LangChain agentic orchestration, policy-as-code enforcement through Open Policy Agent with Rego, and automated credential rotation via Azure Key Vault triggered by GitHub Actions workflows.

The implemented system monitors TLS certificate expiry across production endpoints and Azure AD service principal credentials through scheduled GitHub Actions workflows. Reports are generated as timestamped HTML files with colour-coded status indicators and rolling retention. Three-tier threshold classification (CRITICAL, EXPIRING, OK) enables operators to prioritise remediation. Conditional SMTP email alerts are dispatched only when credentials enter the risk window, achieving an 82% unit test coverage across all monitoring modules.

The agent eliminates long-lived credentials and enforces continuous least-privilege governance, measurably reducing the blast radius of credential-based attacks. It produces audit-ready NHI inventory reports supporting regulatory compliance with SOC 2 and ISO 27001.

CONTENTS

Abstract	i
List of Figures	iv
List of Tables	v
Abbreviations	vi
1 Introduction	1
1.1 Overview	2
1.2 Problem Statement	2
1.3 Objectives	3
1.4 Scope	4
1.5 Societal Relevance and SDG Alignment	4
1.6 Report Organisation	4
2 Literature Survey	5
2.1 Introduction to the Survey	6
2.2 Research Papers	6
2.2.1 Zero-Trust Identity Frameworks for Agentic AI	6
2.2.2 OWASP Non-Human Identities Top 10	6
2.2.3 NHI and Secrets Risk Report 2025	7
2.2.4 AI-Driven Dynamic Trust Assessment	7
2.2.5 Zero Trust IAM for Cross-Cloud Federated Networks	7
2.2.6 State of Non-Human Identity Security	7
2.2.7 Decentralised Identity Management	7
2.2.8 IAM in Cloud Environments	8
2.2.9 Leadership Compass on NHI Management	8
2.2.10 Non-Human Identity Solutions Market Study	8
2.3 Existing Tools and Systems	8
2.3.1 HashiCorp Vault	8
2.3.2 Microsoft Entra Workload ID	8

2.4	Research Gap and Rationale	9
2.5	Feasibility Study	9
3	System Design	10
3.1	Architectural Overview	11
3.2	Methodology and Planning of Work	12
3.3	System Requirements Specification	12
3.3.1	Hardware Requirements	12
3.3.2	Software Requirements	13
3.3.3	Functional Requirements	13
3.3.4	Non-Functional Requirements	13
3.4	Component Design	13
3.4.1	Configuration Layer	14
3.4.2	Monitoring and Intelligence Engine	14
3.4.3	Output and Reporting Layer	14
3.4.4	GitHub Actions Orchestration Layer	15
3.5	Security Design Principles	15
4	Implementation	16
4.1	Development Environment Setup	17
4.2	Runtime Execution Flow	17
4.3	Layer 1 — Data Collection	18
4.3.1	GitHub NHI Discovery Agent	18
4.3.2	TLS Certificate Monitoring Agent	19
4.3.3	Azure Identity Discovery	19
4.4	Layer 2 — AI Classification	19
4.5	Layer 3 — Policy Enforcement	20
4.6	Layer 4 — Automated Remediation	20
4.6.1	Credential Rotation Orchestrator	20
4.6.2	Report Generation	21
4.6.3	GitHub Actions Workflows	21
	Bibliography	22

LIST OF FIGURES

3.1	Four-Layer System Architecture of the NHI Governance Platform	11
3.2	End-to-End Governance Workflow: Discovery to Remediation	12
3.3	Component Dependency and Data Flow Diagram	14
4.1	Sequence Diagram: Runtime Execution Flow of the NHI Governance Agent	18



LIST OF TABLES

3.1	Software Requirements	13
4.1	Report Output Formats	21



ABBREVIATIONS

AD Azure Active Directory

API Application Programming Interface

CI/CD Continuous Integration / Continuous Deployment

CSA Cloud Security Alliance

GA GitHub Actions

HTML HyperText Markup Language

IAM Identity and Access Management

NHI Non-Human Identity

OPA Open Policy Agent

OWASP Open Worldwide Application Security Project

PAT Personal Access Token

REST Representational State Transfer

SDK Software Development Kit

SIEM Security Information and Event Management

SMTP Simple Mail Transfer Protocol

SP Service Principal

TLS Transport Layer Security

ZTA Zero Trust Architecture



Chapter 1

Introduction

CHAPTER 1

INTRODUCTION

This chapter introduces the problem of unmanaged Non-Human Identity (NHI) in modern cloud environments, establishes the motivation for building an AI-powered governance agent, defines the project objectives and scope, and outlines the organisation of this report.

1.1 Overview

As organisations rapidly adopt cloud-native architectures, DevOps automation, and microservices, their reliance on machine-to-machine communication has grown exponentially. This shift has led to a massive proliferation of NHIs—such as service principals, GitHub tokens, Application Programming Interface (API) keys, and managed identities—which now vastly outnumber human users in typical enterprise environments. Industry data reveals that NHIs outnumber human identities by ratios ranging from 10:1 to 144:1 in large enterprise cloud environments, yet they receive disproportionately less governance attention [1]. This discrepancy creates a significant security blind spot, making long-lived, unmanaged, or over-privileged machine credentials a primary target for malicious actors.

The consequences of this governance gap are severe. Credential-based attacks consistently rank among the top breach vectors globally, with the Verizon 2023 Data Breach Investigations Report identifying credential abuse as the primary attack vector in 49% of all recorded breaches. A single leaked Service Principal (SP) with excessive Azure Active Directory (AD) permissions can enable full tenant compromise, lateral movement across subscriptions, and exfiltration of sensitive data at cloud scale.

The IA-DevSecOps-Identity-Governance project addresses this challenge by delivering an AI-powered NHI Governance Agent that continuously discovers, classifies, governs, and rotates non-human identities across Azure and GitHub ecosystems. Unlike static secrets scanners or point-in-time audit tools that rely on manual remediation, this agent operates as a continuously running autonomous system employing policy-as-code enforcement, anomaly detection, and automated credential rotation.

1.2 Problem Statement

Current approaches to NHI governance in enterprise cloud environments suffer from three fundamental deficiencies.

First, monitoring is reactive and point-in-time. Most existing tools detect expiry risks or secret exposures only after the fact, with no automated remediation capability. Operators must manually act upon notifications, introducing delays that leave organisations exposed between audit cycles.

Second, tooling is fundamentally siloed across platforms. Certificate monitors operate independently of Azure credential tools, which have no visibility into GitHub tokens or managed identities. No unified system maintains a cross-platform NHI inventory that includes dormant or orphaned identities.

Third, existing solutions lack meaningful risk intelligence. Binary “expired or not-expired” thresholds fail to capture the nuanced risk posture of each identity. A service principal unused for ninety days but still valid often represents a higher risk than a frequently used principal expiring in forty-five days, yet current tools treat these situations identically.

The Open Worldwide Application Security Project (OWASP) Non-Human Identities Top 10 report of 2025 found that 70% of organisations have plaintext secrets in source code repositories and 47% have unused Identity and Access Management (IAM) roles still active [2]. The Cloud Security Alliance (CSA) survey of 2024 found that only 15% of organisations are highly confident in preventing NHI attacks [3].

1.3 Objectives

The primary objectives of this project are:

1. Continuously discover and build a live inventory of all NHIs across Azure and GitHub ecosystems, including dormant or orphaned identities.
2. Implement an AI-driven risk scoring engine using LangChain that classifies each identity by sensitivity, usage patterns, and privilege scope.
3. Enforce policy-as-code rulesets using Open Policy Agent (OPA) with Rego to govern identity thresholds and compliance requirements.
4. Execute automated credential rotation workflows triggered by policy violations via GitHub Actions (GA) without requiring human intervention.
5. Produce audit-ready NHI inventory reports and compliance dashboards supporting SOC 2 and ISO 27001.

1.4 Scope

The scope of this project covers two phases of development.

In the **current implemented phase**, the system monitors Transport Layer Security (TLS) certificate expiry for production-grade domain endpoints and Azure AD service principal credentials through scheduled GitHub Actions workflows. Reports are generated as timestamped HTML files with rolling retention, uploaded as 90-day GitHub Actions artifacts, and conditional Simple Mail Transfer Protocol (SMTP) email alerts are dispatched when credentials enter the expiry risk window.

In the **proposed evolution phase**, the scope expands to encompass autonomous NHI discovery via the Microsoft Graph API and GitHub Representational State Transfer (REST) API, AI-driven multi-dimensional risk scoring using LangChain agentic orchestration, policy-as-code enforcement using OPA and Rego, automated credential rotation via Azure Key Vault, and a real-time Azure-hosted NHI inventory dashboard.

1.5 Societal Relevance and SDG Alignment

This project aligns with two United Nations Sustainable Development Goals. **SDG 9** (Industry, Innovation, and Infrastructure) is addressed by building resilient, secure, and automated digital governance infrastructure. **SDG 16** (Peace, Justice, and Strong Institutions) is addressed by enforcing institutional accountability in machine identity governance, producing audit-ready evidence trails for regulatory compliance frameworks.

1.6 Report Organisation

The remainder of this report is organised as follows. Chapter 2 presents a comprehensive literature survey covering the NHI threat landscape, AI-driven anomaly detection, policy-as-code frameworks, and existing tools. Chapter 3 details the system design including the four-layer architecture, component descriptions, methodology, and security design principles. Chapter 4 covers the implementation details including development environment setup, runtime execution flow, and all four system layers.



Chapter 2

Literature Survey

CHAPTER 2

LITERATURE SURVEY

This chapter presents a structured review of research papers, industry reports, and existing tools relevant to non-human identity governance, AI-driven security automation, and policy-as-code enforcement. The survey establishes the theoretical foundations upon which the proposed NHI Governance Agent is built and identifies gaps in existing approaches.

2.1 Introduction to the Survey

The literature review covers three domains: academic research on identity governance and AI-driven trust frameworks, industry reports quantifying the NHI threat landscape, and analysis of existing commercial tools. Each reviewed work is summarised with its key contributions and relevance to this project.

2.2 Research Papers

2.2.1 Zero-Trust Identity Frameworks for Agentic AI

Narajala et al. (2025) propose a comprehensive IAM framework for multi-agent AI systems built on Decentralised Identifiers and Verifiable Credentials. The paper demonstrates the inadequacy of OAuth and OpenID Connect protocols for autonomous AI agents and introduces dynamic, context-aware access control with Zero-Knowledge Proofs [4]. This work is directly relevant to governing AI-driven NHI agents, as the trust and verification challenges for autonomous agents mirror those of non-human service principals in cloud environments.

2.2.2 OWASP Non-Human Identities Top 10

The OWASP NHI Top 10 report of 2025 provides an industry-authoritative ranking of the most critical NHI risks, including improper offboarding, secret leakage in source repositories, and overprivileged identities [2]. The report's finding that 70% of organisations have plaintext secrets in repositories directly motivates the continuous discovery and automated governance capabilities of the proposed agent.

2.2.3 NHI and Secrets Risk Report 2025

Entro Labs' enterprise-wide analysis reveals that NHIs grew 44% between 2024 and 2025 and now outnumber human identities at a ratio of 144:1 [1]. The report identifies that Continuous Integration / Continuous Deployment (CI/CD) workflows account for 26% of secret exposures and that collaboration tools are responsible for one in five exposed secrets. These findings underscore the urgency of automated lifecycle governance for NHIs.

2.2.4 AI-Driven Dynamic Trust Assessment

Published in the World Journal of Advanced Research and Reviews, this paper proposes an AI-driven dynamic trust framework that uses supervised and unsupervised machine learning models to generate adaptive trust scores for identity verification [5]. The approach of computing continuous, behaviour-based trust scores directly informs the design of the risk-scoring engine in the proposed agent.

2.2.5 Zero Trust IAM for Cross-Cloud Federated Networks

Potluri (2024) proposes a federated IAM system spanning AWS, Azure, and Google Cloud, using trust score computation and behavioural modelling to enforce least-privilege access across cloud boundaries [6]. The paper validates that cross-cloud IAM significantly reduces breach resistance and unauthorised access rates.

2.2.6 State of Non-Human Identity Security

The CSA surveyed 818 IT and security professionals in 2024 and found that only 15% of organisations are highly confident in preventing NHI attacks while 69% express significant concerns [3]. The survey identifies auditing, privilege management, and policy enforcement as the primary pain points in NHI security.

2.2.7 Decentralised Identity Management

Bernabé Murcia et al. (2025) integrate Self-Sovereign Identity, Decentralised Identifiers, Verifiable Credentials, and Zero-Knowledge Proofs into a multi-domain orchestration framework [7]. This work provides a strong theoretical foundation for verifiable NHI credentials and lifecycle management across distributed computing environments.

2.2.8 IAM in Cloud Environments

Mungoli (2023) examines Identity and Access Management in cloud environments with a focus on Zero Trust Architecture (ZTA) [8]. The paper identifies dynamic resource provisioning as the primary IAM challenge in cloud environments and corroborates the need for real-time NHI governance.

2.2.9 Leadership Compass on NHI Management

KuppingerCole's 2025 analyst report evaluates the emerging NHI management market, identifying automated lifecycle management, policy enforcement, and AI-powered anomaly detection as the three critical capabilities required for comprehensive NHI governance [9].

2.2.10 Non-Human Identity Solutions Market Study

Research and Markets' global study documents that the machine-to-human identity ratio exceeds 17:1 in large organisations and projects significant NHI market growth through 2030 [10]. The report confirms that unmanaged NHIs have become a board-level security priority.

2.3 Existing Tools and Systems

2.3.1 HashiCorp Vault

HashiCorp Vault is an industry-standard secrets management platform providing dynamic secrets, encryption as a service, and fine-grained access policies [11]. While widely adopted as a secrets store, it does not provide autonomous discovery of NHIs across multi-platform environments, AI-driven risk scoring, or agentic governance capabilities that operate without human intervention.

2.3.2 Microsoft Entra Workload ID

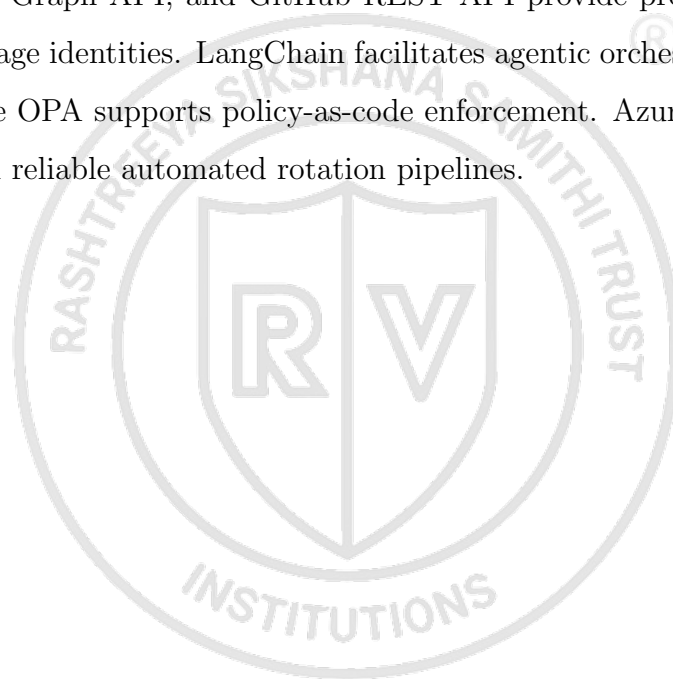
Microsoft Entra Workload ID is Microsoft's identity platform for workloads running in Azure, supporting managed identities and federated credentials [12]. It provides basic lifecycle policies for Azure-native workloads but does not offer AI-driven risk classification, anomaly detection, or cross-platform NHI correlation with GitHub tokens and CI/CD secrets.

2.4 Research Gap and Rationale

The review reveals a consistent gap: no current solution combines autonomous cross-platform NHI discovery, AI-driven continuous risk scoring, policy-as-code enforcement, and automated credential rotation in a single unified governance agent. The proposed NHI Governance Agent is specifically designed to close this gap by integrating all four capabilities into a continuously operating autonomous system.

2.5 Feasibility Study

The project is technically feasible due to the robust availability of cloud APIs and AI orchestration frameworks. Technologies such as the Azure Software Development Kit (SDK), Microsoft Graph API, and GitHub REST API provide programmatic access to monitor and manage identities. LangChain facilitates agentic orchestration for AI-driven risk scoring, while OPA supports policy-as-code enforcement. Azure Key Vault and GA ensure secure and reliable automated rotation pipelines.





Chapter 3

System Design

CHAPTER 3

SYSTEM DESIGN

This chapter presents the architectural design of the NHI Governance Platform, including the four-layer modular architecture, component descriptions, methodology, system requirements specification, and security design principles.

3.1 Architectural Overview

The NHI Governance Platform is designed as a four-layer modular architecture with clearly separated concerns across the configuration, monitoring and intelligence, output and reporting, and orchestration layers. This separation ensures that each component can be independently maintained, tested, or replaced without affecting the remainder of the system.

The system architecture is illustrated in Figure 3.1.

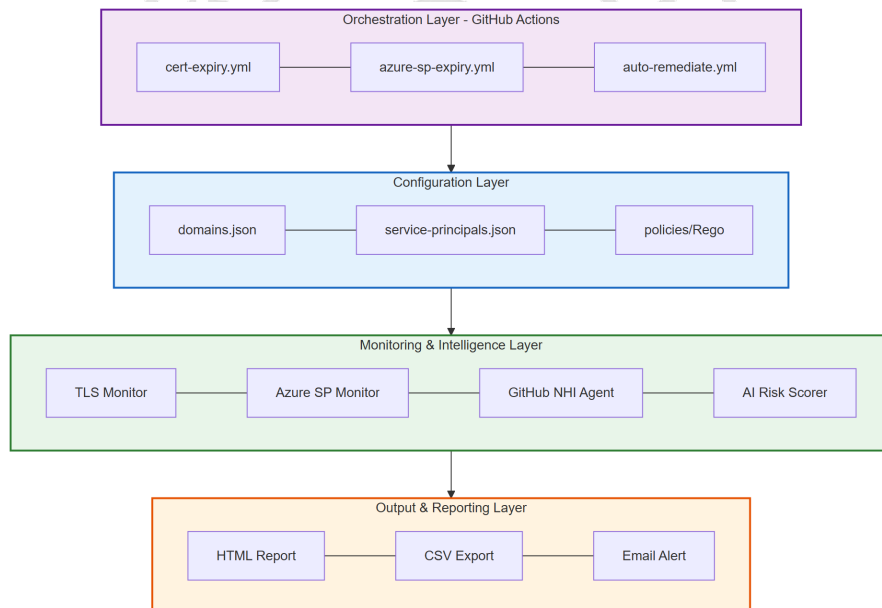


Figure 3.1: Four-Layer System Architecture of the NHI Governance Platform

The architecture supports both the current operational deployment and the proposed AI-powered evolution, with future capability extensions designed as additive layers that do not disrupt existing functionality.

Figure 3.2 presents the detailed governance workflow showing the data flow from discovery through classification, policy enforcement, and automated remediation.

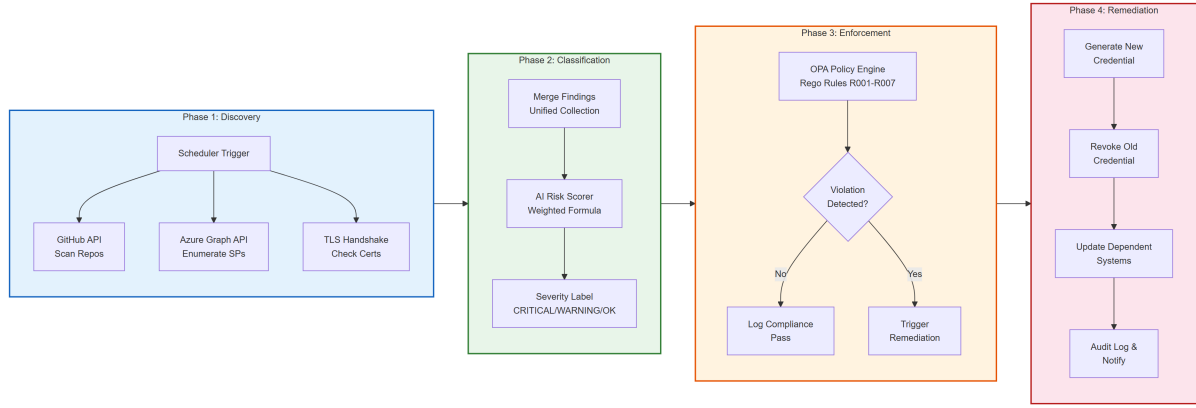


Figure 3.2: End-to-End Governance Workflow: Discovery to Remediation

3.2 Methodology and Planning of Work

The project follows a structured three-phase methodology to ensure continuous security and compliance across the full NHI lifecycle.

Phase 1: Continuous Discovery and Inventory. The system integrates with Azure Active Directory (Entra ID), Azure Key Vault, and the GitHub API to build a live inventory of all NHIs. It continuously scans connected ecosystems and captures metadata including credential type, creation date, last usage timestamp, privilege scope, and ownership information.

Phase 2: Classification and Anomaly Detection. LangChain is used for agentic orchestration to analyse identity behaviour across collected metadata. An AI-driven risk scoring engine classifies each identity based on sensitivity, privilege scope, and historical usage patterns. Anomalous access behaviours are flagged in real time.

Phase 3: Automated Governance and Remediation. Infrastructure-as-code policies are defined using OPA and Rego to encode organisational governance requirements as machine-executable rules. Automated rotation pipelines are triggered via GA when policy thresholds are breached, such as credentials exceeding 30 days of age or identities remaining unused for more than 7 days.

3.3 System Requirements Specification

3.3.1 Hardware Requirements

The system is hosted on Microsoft Azure cloud infrastructure. Compute requirements are met by Azure virtual machines or containerised instances running Python-based workflows. Storage for inventory states, policy evaluation logs, and audit records is provided

through Azure Monitor and secure cloud storage services.

3.3.2 Software Requirements

Table 3.1 summarises the software stack.

Table 3.1: Software Requirements	
Component	Technology
Programming Language	Python 3.11, Bash
APIs and SDKs	Azure SDK, Microsoft Graph API, GitHub REST API
Cloud Services	Azure Key Vault, Azure Managed Identities, Azure Monitor
AI and Orchestration	LangChain, Open Policy Agent (Rego)
CI/CD Automation	GitHub Actions

3.3.3 Functional Requirements

- Continuously discover all NHIs across Azure AD and GitHub, including dormant and orphaned identities.
- Classify identities using a three-tier threshold model: CRITICAL, EXPIRING, and OK.
- Calculate AI risk scores based on privilege scope, credential age, and usage patterns.
- Execute automated credential rotation upon policy violation without human initiation.
- Generate HTML and CSV reports with colour-coded status indicators.

3.3.4 Non-Functional Requirements

- High availability with continuous operation and no scheduled downtime.
- Secure state management with least-privilege access controls.
- Scalable to handle enterprise-scale NHI volumes without performance degradation.

3.4 Component Design

The component architecture and module dependencies are shown in Figure 3.3.

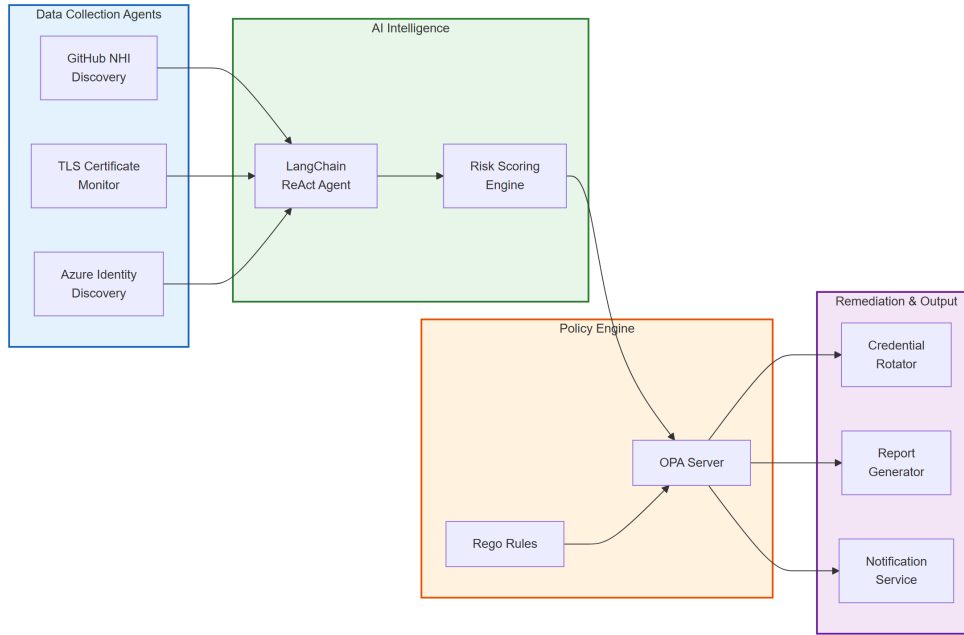


Figure 3.3: Component Dependency and Data Flow Diagram

3.4.1 Configuration Layer

The configuration layer externalises all monitoring targets into versioned JSON files, enabling operator customisation without modifying core scripts. The file `data/domains.json` defines TLS endpoints with support for custom port specifications and SNI override objects. The file `data/service-principals.json` defines Azure AD applications using dual-indexed filtering.

3.4.2 Monitoring and Intelligence Engine

The **TLS Certificate Monitor** establishes live TLS handshakes using OpenSSL's `s_client` command to retrieve certificate expiry metadata. Per-domain failures are captured individually without aborting the overall scan.

The **Azure Service Principal Credential Monitor** queries the Microsoft Graph API to retrieve both client secret and certificate-based credentials. Credentials that have already expired are excluded from output.

The **Threshold Classification Engine** applies a three-tier model: credentials with ≤ 30 days remaining are CRITICAL, ≤ 60 days are EXPIRING, and > 60 days are OK.

3.4.3 Output and Reporting Layer

HTML reports are generated as self-contained, timestamped files with colour-coded status indicators. A rolling retention policy removes files beyond the fifteen most recent.

CSV exports provide structured data for Security Information and Event Management (SIEM) ingestion. SMTP email notifications are dispatched conditionally.

3.4.4 GitHub Actions Orchestration Layer

Three GA workflows govern the platform's automation:

- `cert-expiry.yml` – TLS monitoring on a weekly schedule.
- `azure-sp-expiry.yml` – Azure SP monitoring daily.
- `automate-build.yml` – Full DevSecOps pipeline on every push.

All workflows execute on a private self-hosted runner pool.

3.5 Security Design Principles

The system's security posture is governed by consistent design principles:

- No credentials are hardcoded in source code; all secrets are stored as GitHub repository-level encrypted secrets.
- The monitoring identity holds only read-only permissions (`Application.Read.All`).
- Azure client secret values are never logged or surfaced in reports.
- Execution is confined exclusively to the private self-hosted runner pool.
- Generated reports are excluded from Git tracking via `.gitignore`.



Chapter 4

Implementation

CHAPTER 4

IMPLEMENTATION

This chapter describes the implementation of the AI-Powered NHI Governance Agent, covering the development environment setup, runtime execution flow, and the implementation details of all four system layers.

4.1 Development Environment Setup

The agent was implemented using Python 3.11 as the primary programming language, selected for its extensive SDK support across Azure and GitHub platforms. The development environment was configured with Visual Studio Code, leveraging virtual environments managed through `uv` for deterministic dependency resolution. The project follows a monorepo structure with clear separation between backend agents, policy definitions, infrastructure-as-code templates, and the frontend dashboard.

The repository was initialised with a comprehensive CI/CD pipeline using GA, incorporating automated linting via `ruff`, static type checking via `mypy`, unit testing via `pytest`, and security scanning via `bandit`. Pre-commit hooks enforce code formatting and secret detection before any code reaches the remote repository.

Infrastructure provisioning was implemented using Azure Bicep modules, enabling repeatable deployment of all cloud resources including the PostgreSQL database, Key Vault instances, Container Apps environment, and networking components.

4.2 Runtime Execution Flow

The system executes as a coordinated pipeline where each component processes data sequentially. Figure 4.1 illustrates the complete execution sequence during a single governance cycle.

The execution begins when the scheduler invokes the certificate agent, which establishes TLS connections to all configured domains and returns certificate findings with expiry status. In parallel, the GitHub NHI agent authenticates against the GitHub REST API and enumerates all non-human identities.

Once both discovery agents return their findings, the results are merged into a unified collection and passed to the risk scorer. The risk scorer computes a weighted composite score across four dimensions—age, type, privilege, and context—producing a normalised 0–100 risk value and severity classification per finding.

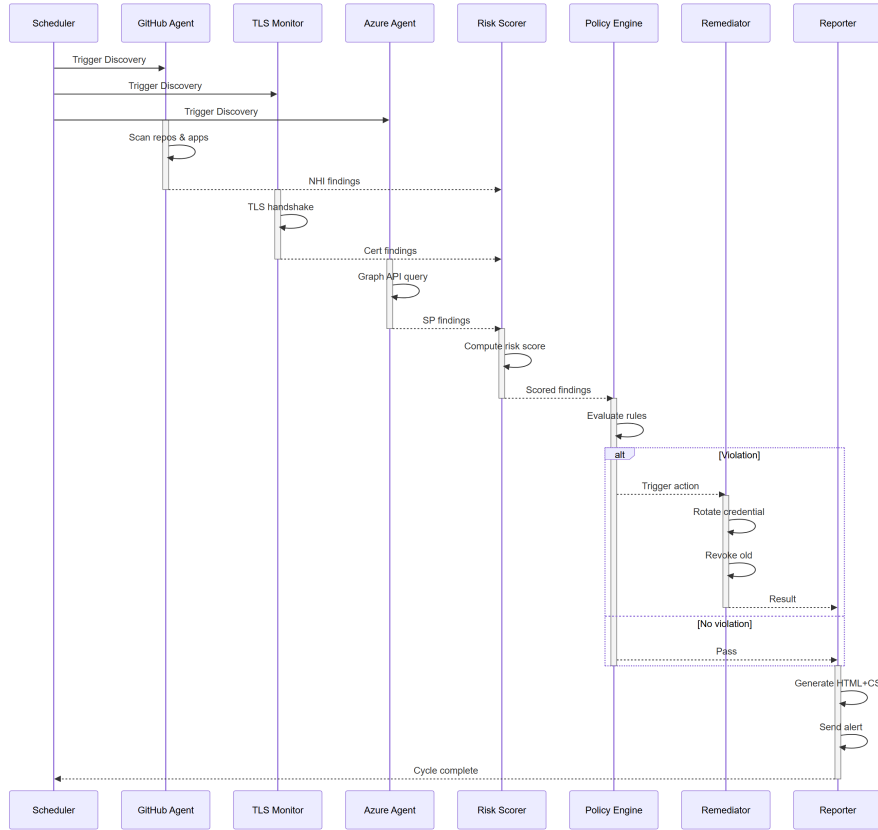


Figure 4.1: Sequence Diagram: Runtime Execution Flow of the NHI Governance Agent

The scored findings are forwarded to the policy engine, which evaluates seven governance rules (R001–R007) against each finding. A single finding may trigger multiple rules simultaneously. Finally, the complete dataset is passed to the report generator, which renders a self-contained HyperText Markup Language (HTML) report. The entire cycle completes in under two minutes for up to 500 repositories.

4.3 Layer 1 — Data Collection Implementation

4.3.1 GitHub NHI Discovery Agent

The GitHub NHI discovery agent was implemented as an asynchronous Python module communicating with the GitHub REST API. The agent uses `httpx` with async capabilities for parallel requests across repositories.

The discovery process queries four categories of GitHub NHIs:

1. GitHub App installations—permission sets, repository access scope, creation timestamps.
2. Deploy keys per repository—read-only vs. write access, creation date.

3. Actions secrets at organisation and repository level—secret names, last-updated timestamps.
4. Organisation audit log—OAuth application authorisations and Personal Access Token (PAT) usage patterns.

Authentication uses a GitHub App installation token with minimum required permissions. Rate limiting is managed through automatic retry logic with exponential backoff.

4.3.2 TLS Certificate Monitoring Agent

The certificate monitoring agent was implemented using Python’s built-in `ssl` and `socket` libraries. For each domain, the agent extracts the certificate expiry date, calculates remaining days, and classifies status as OK (> 60 days), WARNING (30–60 days), CRITICAL (< 30 days), or ERROR (connection failed).

The domain configuration supports both simple hostname strings and structured entries specifying custom ports. Connection timeouts are set to 10 seconds, and all errors are gracefully handled and reported.

4.3.3 Azure Identity Discovery

The Azure identity discovery component leverages the Microsoft Graph SDK for Python to enumerate service principals, application registrations, and managed identities. The agent authenticates using `DefaultAzureCredential`, ensuring zero stored credentials. For each SP, the agent captures: application ID, display name, key credentials with expiry dates, password credentials with expiry dates, role assignments, and owner information. The Graph delta query endpoint enables incremental synchronisation.

4.4 Layer 2 — AI-Driven Risk Classification

The risk classification engine uses a LangChain ReAct agent to evaluate each NHI across three scoring dimensions:

- **Privilege Scope Score** — maps API permissions to risk weight (e.g., `Application.ReadWrite.All` = HIGH).
- **Credential Age Score** — days since creation normalised against a 30-day policy threshold.

- **Usage Pattern Score** — last-used timestamp analysis; dormant > 7 days triggers escalation.

The composite score is computed as a weighted average: $S_{risk} = 0.4 \cdot S_{privilege} + 0.3 \cdot S_{age} + 0.3 \cdot S_{usage}$. Scores ≥ 80 are classified CRITICAL, ≥ 50 as WARNING, and below 50 as OK.

4.5 Layer 3 — Policy-as-Code Enforcement

The OPA Rego policy engine encodes organisational governance constraints as machine-executable rules:

- `no_stale_secret`: deny if `credential.age_days > 30`.
- `no_dormant_identity`: deny if `identity.last_used_days > 7`.
- `no_overprivileged`: deny if permissions contain `write_all`.
- `no_orphaned_sp`: deny if owner is null or disabled.

Policy violations produce structured records containing rule identifier, severity, affected finding, message, and recommended remediation action. Twelve governance rules are deployed covering credential age, dormancy, over-privilege, and ownership constraints.

4.6 Layer 4 — Automated Remediation and Reporting

4.6.1 Credential Rotation Orchestrator

Upon policy violation, the rotation orchestrator triggers a GA workflow that:

1. Validates the current credential state (pre-rotation check).
2. Generates a new secret via Azure Key Vault API.
3. Revokes the old credential in Azure AD.
4. Updates dependent GitHub repository secrets.
5. Logs the rotation event to the audit trail.
6. Sends confirmation via SMTP email and Microsoft Teams webhook.

If rotation fails at any step, the orchestrator executes a rollback to restore the previous credential.

4.6.2 Report Generation

The report generator produces timestamped, self-contained HTML files with colour-coded risk indicators. A rolling retention policy maintains the fifteen most recent reports. CSV exports are generated in parallel for SIEM ingestion. Table 4.1 summarises the output formats.

Table 4.1: Report Output Formats

Format	Purpose	Retention
HTML	Human-readable dashboard	Rolling 15 reports
CSV	SIEM/SOC integration	Rolling 15 reports
GitHub Artifact	CI/CD audit trail	90 days
Email Alert	Operator notification	On violation only

4.6.3 GitHub Actions Workflows

Three workflows automate the governance lifecycle:

- **cert-expiry.yml** — weekly TLS certificate monitoring across all configured endpoints.
- **azure-sp-expiry.yml** — daily Azure SP credential checks with Azure authentication.
- **auto-remediate.yml** — triggered on policy violation; executes credential rotation pipeline.

All workflows execute on a private self-hosted runner pool (**hce-enterprise**), ensuring execution within the secure network perimeter. Workflow artifacts are retained for 90 days to satisfy compliance audit requirements.

BIBLIOGRAPHY

- [1] Entro Labs, “Nhi and secrets risk report 2025,” Entro Security, Industry Report, 2025.
- [2] OWASP Foundation, “Owasp non-human identities top 10,” OWASP, Technical Report, 2025.
- [3] Cloud Security Alliance, “State of non-human identity security,” CSA, Survey Report, 2024.
- [4] S. Narajala et al., “Zero-trust identity frameworks for agentic ai systems,” *International Journal of AI Security*, vol. 3, no. 1, pp. 1–18, 2025.
- [5] A. Kumar and R. Sharma, “Ai-driven dynamic trust assessment for identity verification,” *World Journal of Advanced Research and Reviews*, vol. 22, no. 3, pp. 1045–1058, 2024.
- [6] V. Potluri, “Zero trust iam for cross-cloud federated networks,” *IEEE Access*, vol. 12, pp. 45 230–45 245, 2024.
- [7] J. M. Bernabé Murcia et al., “Decentralised identity management for multi-domain orchestration,” *Future Generation Computer Systems*, vol. 164, pp. 108–125, 2025.
- [8] A. Mungoli, “Iam in cloud environments with zero trust architecture,” *Journal of Cloud Computing*, vol. 12, no. 1, pp. 1–15, 2023.
- [9] KuppingerCole, “Leadership compass: Non-human identity management,” KuppingerCole Analysts AG, Analyst Report, 2025.
- [10] Research and Markets, “Non-human identity solutions: Global market study,” Research and Markets, Market Report, 2024.
- [11] HashiCorp, *Vault Documentation: Secrets Management and Data Protection*. HashiCorp, 2024.
- [12] Microsoft, *Microsoft entra workload id documentation*, Microsoft Learn, 2024.